

CISSP Printable Practice Exam 21 - Domain 5 - Identity and Access Management (IAM)

Practice Exam 03 - Domain 5

Choose the best answer for each question. For multi-select items, select all required answers.

Question 1 (CISSP3-079)

Scenario: A global engineering firm ships hardware authenticators to remote employees. The security manager is concerned that a device intercepted in transit could be activated by someone other than the intended employee.

Which enrollment design BEST addresses this concern?

- A. Activate every device before shipment so employees can use it immediately
- B. Require identity proofing through an independent trusted channel before binding and activating the device
- C. Allow the recipient to activate the device using information printed on the shipping label
- D. Use package delivery confirmation as sufficient evidence of the recipient's identity

Question 2 (CISSP3-080)

Scenario: A wealth-management portal terminates sessions after fifteen minutes of inactivity. However, an authenticated user who remains active can keep the same session open for several days, increasing exposure if the workstation or session token is later compromised.

What additional control would MOST directly limit this exposure?

- A. Increase the inactivity timeout during normal business hours
- B. Require users to close the browser after completing each transaction
- C. Issue a second session token whenever the existing session becomes active
- D. Enforce a maximum absolute session lifetime followed by reauthentication

Question 3 (CISSP3-081)

Scenario: A media company has experienced convincing phishing attacks that capture passwords and one-time codes in real time. It is redesigning remote administrator authentication and wants the strongest protection against an attacker relaying credentials to an imitation sign-in site.

Which approach BEST meets the objective?

- A. Use a cryptographic authenticator that verifies the legitimate service before completing authentication
- B. Send a longer numeric code to the administrator's registered telephone
- C. Require two different passwords entered on separate pages
- D. Add personal questions after the administrator enters a password and one-time code

Question 4 (CISSP3-082)

Scenario: A ticketing portal stores its authenticated session identifier in a browser cookie. The security architect wants to reduce exposure through client-side script access and accidental transmission over an unencrypted connection.

Which TWO cookie controls MOST directly address these risks? Select 2 of the 5 options below.

- A. Extend the cookie lifetime so users authenticate less frequently
- B. Mark the cookie so client-side scripts cannot read it

- C. Store the user's password as an additional cookie value
- D. Restrict the cookie to encrypted transport
- E. Use the same session identifier before and after authentication

Question 5 (CISSP3-083)

Scenario: A cloud-operations team launches production changes through an automation platform. Every change appears in target-system logs under the platform's service identity, so investigators cannot determine which engineer initiated a particular job.

Which improvement BEST establishes accountability without removing automation?

- A. Give every engineer the service identity's permanent credential
- B. Record only the final configuration state after each automated job
- C. Require individual authentication to the platform and preserve the initiator's identity in tamper-resistant job records
- D. Rotate the shared service credential more frequently while keeping initiation anonymous

Question 6 (CISSP3-084)

Scenario: A tax-processing service accepts signed authentication assertions from a trusted identity provider. A security review finds that a captured valid assertion could be submitted repeatedly because the service does not evaluate its intended recipient or track whether it has already been consumed.

Which TWO relying-party controls would BEST reduce this replay risk? Select 2 of the 5 options below.

- A. Validate that the assertion is intended for this service and is within its permitted time window
- B. Accept assertions for any audience when the identity provider's signature is valid
- C. Extend assertion validity to accommodate users in different time zones
- D. Convert every assertion into a permanent local password
- E. Reject reuse of an assertion identifier that has already been processed

Question 7 (CISSP3-085)

Scenario: A benefits application needs delegated access to read an employee's basic profile from a workforce API. The requested access token currently permits reading and modifying the employee's payroll, contact, and tax information.

What is the BEST authorization change?

- A. Issue a longer-lived token so the application requests authorization less often
- B. Give the application an administrative token because it serves all employees
- C. Define and request a narrow read-only scope limited to the profile data required
- D. Replace delegated authorization with storage of each employee's workforce password

Question 8 (CISSP3-086)

Scenario: An online learning service begins an OpenID Connect login from a user's browser. The service later receives a valid response but does not verify that the response belongs to the same browser transaction that initiated the request.

Which control MOST directly binds the response to the initiating session?

- A. Grant the identity token every available user-profile claim
- B. Generate an unpredictable transaction value, store it in the initiating session, and verify it on return
- C. Allow the browser to choose the identity token's issuer

- D. Reuse one transaction value for all users so responses are consistent

Question 9 (CISSP3-087)

Scenario: A professional association will federate employee access to an external training provider. The provider needs to know whether a user is an active employee and which training tier applies, but it has requested full birth dates, home addresses, and internal personnel numbers as well.

What should the identity architect recommend?

- A. Release every requested attribute because the provider participates in the federation
- B. Send the employee's entire directory record but require the provider to delete it annually
- C. Replace the federation with a shared account that discloses no user attributes
- D. Release only the validated employment status and training-tier attributes required for the service

Question 10 (CISSP3-088)

Scenario: A nonprofit disables a departed employee at its identity provider. The employee can still use an external fundraising service because the service maintains a long-lived local session and does not receive or check revocation information until the session expires.

Which design change BEST reduces this termination gap?

- A. Implement supported logout or revocation signaling and require appropriately short local session revalidation
- B. Increase the external service's local session lifetime to reduce dependency on the identity provider
- C. Create a permanent local password for every federated user as a backup
- D. Retain departed employees as active federation subjects until all sessions expire naturally

Question 11 (CISSP3-089)

Scenario: An international manufacturer has stable job functions that map well to roles. Access to certain engineering designs must also depend on the user's current project, the design's sensitivity, and the country from which the request originates.

Which authorization approach BEST fits these requirements?

- A. Create a permanent role for every possible combination of project, sensitivity, and country
- B. Use roles for job permissions and evaluate contextual attributes for the additional restrictions
- C. Let each user grant access to coworkers whenever project conditions change
- D. Assign one mandatory label to each job title and ignore request location

Question 12 (CISSP3-090)

Scenario: A counseling center lets each clinician share patient-record folders through owner-managed access lists. Compliance leadership now requires organization-wide restrictions that individual folder owners cannot weaken or bypass.

Which change BEST satisfies the new requirement?

- A. Continue discretionary sharing but ask owners to review lists more frequently
- B. Allow patients to inherit the folder owner's administrative permissions

- C. Enforce centrally defined access policy that constrains owner-granted permissions
- D. Permit any authenticated clinician to access every folder during working hours

Question 13 (CISSP3-091)

Scenario: An analyst holds a clearance equal to the classification of a restricted intelligence report but is not assigned to the program that produced it. The mandatory access system also supports compartments representing approved program access.

How should the access request be handled?

- A. Permit access because equal clearance alone establishes need-to-know
- B. Permit access if the analyst agrees not to redistribute the report
- C. Let the report's author bypass the compartment restriction for this request
- D. Deny access because the required compartment authorization is absent

Question 14 (CISSP3-092)

Scenario: A public-records platform places a policy enforcement gateway in front of its web interface. Security testing finds that clients can call a legacy application endpoint directly and reach the same records without passing through the gateway.

What is the MOST important corrective action?

- A. Remove or restrict the bypass path so every request is mediated and the policy decision is enforced
- B. Add more authorization rules to the central decision point while leaving the legacy path open
- C. Increase the gateway's logging retention without changing network reachability
- D. Ask users to prefer the web interface when requesting sensitive records

Question 15 (CISSP3-093)

Scenario: An executive normally may approve moderate-value purchases. A current request is within the executive's entitlement but originates from an unfamiliar device in a new location and is substantially larger than recent approvals. Policy permits adaptive controls.

Which response BEST balances business continuity and risk?

- A. Permanently remove the executive's purchasing role after the first unusual request
- B. Approve the request automatically because the baseline role permits it
- C. Require additional verification or approval before permitting this elevated-risk transaction
- D. Grant a broader role so future large purchases no longer appear anomalous

Question 16 (CISSP3-094)

Scenario: An employee begins a six-month leave of absence. The organization must prevent sign-in during the leave, preserve ownership and audit history, and restore only still-appropriate access if the employee returns.

Which lifecycle action is BEST?

- A. Leave the account active and rely on the employee not to use it
- B. Delete the identity and recreate a new one with the same name after the leave
- C. Transfer the employee's credentials to the manager until the return date
- D. Disable interactive access, preserve the identity record, and require entitlement validation before reactivation

Question 17 (CISSP3-095)

Scenario: A media-streaming company reviews administrator entitlements. One engineer retains production database privileges from a completed migration, has not used them for four months, and has no current operational responsibility requiring that access.

What should the reviewer do?

- A. Retain the privileges because they were valid during the migration
- B. Remove the privileges and require a new approved request if a future need arises
- C. Convert the unused privileges into a shared team administrator account
- D. Keep the privileges but change the database password on the normal schedule

Question 18 (CISSP3-096)

Scenario: A research hospital is standardizing requests for access to a sensitive clinical dataset. The workflow must establish both that the user's duties require access and that the dataset's accountable owner accepts the requested level of use.

Which TWO approvals BEST satisfy these requirements? Select 2 of the 5 options below.

- A. The user's manager confirms the role-related business need
- B. The requester approves the request after acknowledging policy
- C. The dataset owner authorizes the requested permissions
- D. A coworker confirms that similar access would be convenient
- E. The identity platform approves the request solely because the account exists

Question 19 (CISSP3-097)

Scenario: A financial-technology team grants a developer elevated troubleshooting access for two hours. The current system lets the developer repeatedly extend the grant without a new approval, allowing temporary privilege to continue for days.

Which change BEST preserves the temporary nature of the access?

- A. Require each extension to have renewed justification and approval, with a firm maximum duration
- B. Convert the entitlement to permanent access after the first successful extension
- C. Allow unlimited extensions but send the developer a daily reminder
- D. Remove expiration so the identity platform no longer processes repeated requests

Question 20 (CISSP3-098)

Scenario: A manufacturing company merges two departments. The identity team proposes combining their existing roles by taking the union of all permissions and assigning the result to every employee in the new department.

What should occur BEFORE the combined role is assigned?

- A. Assign the union role temporarily and wait for users to report permissions they do not need
- B. Preserve every legacy permission because removing access could inconvenience employees
- C. Let the identity platform choose permissions based only on their frequency of past use
- D. Have accountable business and resource owners define required duties, remove incompatible access, and approve the revised role

ANSWER KEY AND EXPLANATIONS

Question 1 (CISSP3-079) - Correct: B

Independent identity proofing before binding the authenticator confirms that the person activating it is the intended employee, even if the package was intercepted. Pre-activation increases exposure in transit. Shipping-label information and delivery confirmation establish possession of a package, not the identity of the person performing activation.

Question 2 (CISSP3-080) - Correct: D

An absolute lifetime ends the authenticated session after a defined period even when activity continues, requiring the user to authenticate again. Extending the inactivity timeout increases exposure. User instructions are not reliably enforced, and issuing additional tokens does not place a firm boundary on the original authenticated state.

Question 3 (CISSP3-081) - Correct: A

A verifier-bound cryptographic authenticator can resist credential phishing because authentication is tied to the legitimate service rather than to a transferable secret or code. Longer one-time codes can still be relayed in real time. Two passwords remain one factor category, and personal questions rely on reusable knowledge that a convincing phishing flow may also capture.

Question 4 (CISSP3-082) - Correct: B, D

Preventing client-side script access reduces theft through script execution, while restricting the cookie to encrypted transport prevents it from being sent over an unprotected connection. A longer lifetime increases the opportunity for misuse. Storing a password in a cookie creates a more serious credential risk, and retaining the preauthentication identifier enables session-fixation exposure.

Question 5 (CISSP3-083) - Correct: C

Individual authentication combined with protected records linking each engineer to the submitted job provides attribution across the automation layer. Sharing the service credential weakens custody and identity. Final-state records may show what changed but not who initiated it, and credential rotation improves secret hygiene without correcting anonymous job submission.

Question 6 (CISSP3-084) - Correct: A, E

Audience and time validation limit where and when an assertion may be used, while tracking consumed assertion identifiers prevents repeated acceptance of the same assertion. A valid signature alone does not make an assertion appropriate for every recipient. Longer validity expands the replay window, and converting assertions into passwords creates persistent credentials rather than controlling federation replay.

Question 7 (CISSP3-085) - Correct: C

A narrowly defined read-only scope limits the application to the data and action required, applying least privilege to the delegated grant. A longer lifetime increases exposure without reducing authority. Administrative access is excessive, and storing workforce passwords abandons the security benefit of delegated authorization.

Question 8 (CISSP3-086) - Correct: B

An unpredictable state value associated with the initiating browser session lets the client confirm that the returned response corresponds to its own request and helps prevent login cross-site request forgery. Additional profile claims do not bind transactions. The client must validate the expected issuer, and a shared value is predictable and cannot distinguish

concurrent sessions.

Question 9 (CISSP3-087) - Correct: D

Federation should disclose only attributes needed for the relying service's defined purpose. Employment status and training tier satisfy the stated access requirement without exposing unnecessary personal data. Trust membership does not justify unrestricted disclosure, later deletion does not remove initial overcollection, and a shared account sacrifices individual accountability.

Question 10 (CISSP3-088) - Correct: A

Revocation or logout signaling, combined with session lifetimes that require timely revalidation, lets the relying service respond to an identity disabled upstream. Longer sessions enlarge the gap. Permanent local passwords create a second unmanaged access path, and delaying identity disablement intentionally preserves unauthorized access.

Question 11 (CISSP3-089) - Correct: B

A hybrid approach uses RBAC for stable job-based permissions and attribute-based conditions for dynamic project, resource, and location constraints. Encoding every combination as a role causes role explosion. User discretion weakens consistent enforcement, while a job-title label alone cannot represent all of the changing conditions.

Question 12 (CISSP3-090) - Correct: C

Centrally enforced policy prevents individual owners from overriding required restrictions while still allowing controlled delegation where permitted. More frequent review does not remove owner discretion. Administrative inheritance broadens privilege, and time-limited access for all clinicians does not establish a legitimate need for each patient record.

Question 13 (CISSP3-091) - Correct: D

A sufficient clearance establishes eligibility but does not by itself create need-to-know. The missing program compartment means the analyst is not authorized for this resource. A personal promise cannot replace access policy, and individual authors should not bypass centrally enforced mandatory restrictions.

Question 14 (CISSP3-092) - Correct: A

Authorization is effective only when every relevant request reaches an enforcement point that applies the decision. Additional policy and longer logging cannot protect a path that bypasses enforcement. User guidance is not a security boundary and cannot replace complete mediation of the legacy endpoint.

Question 15 (CISSP3-093) - Correct: C

A contextual challenge or additional approval is proportionate because the request is entitled but carries elevated risk signals. Permanent role removal is excessive without further evidence, while automatic approval ignores the adaptive policy. Broadening the role reduces control and does not address the anomalous device, location, or transaction characteristics.

Question 16 (CISSP3-094) - Correct: D

Disabling access preserves attribution and ownership history while preventing use during the temporary absence. Revalidation before reactivation accounts for organizational or role changes during the leave. Keeping the account active leaves unnecessary exposure, deletion disrupts identity continuity, and credential transfer violates individual accountability.

Question 17 (CISSP3-095) - Correct: B

The migration no longer supplies a business need, recent use is absent, and the entitlement is highly privileged, so removal is consistent with least privilege. A past approval does not establish an ongoing requirement. A shared account weakens attribution, and password rotation does not correct unnecessary authorization.

Question 18 (CISSP3-096) - Correct: A, C

The manager is positioned to validate that access is necessary for the user's assigned duties, while the dataset owner is accountable for authorizing access to the protected resource. Self-approval and coworker convenience do not provide independent authority. The existence of an identity is a provisioning prerequisite, not evidence of business need or owner authorization.

Question 19 (CISSP3-097) - Correct: A

Fresh justification and approval prevent an extension mechanism from silently converting time-bound access into standing privilege, while a maximum duration creates an enforceable boundary. Permanent access and removal of expiration defeat the control objective. Reminders do not independently authorize continued elevated access.

Question 20 (CISSP3-098) - Correct: D

Role redesign should begin with current business duties, least privilege, and conflict analysis, validated by owners who understand the work and resources. Automatically unioning legacy permissions propagates excessive and incompatible access. User complaints and past-use frequency can inform analysis but cannot replace accountable authorization of the revised role.